LINEAMIENTO CODIGO SEGURO DE ALFA

Tabla de Contenido

1. OBJETIVO: 3
2. INTRODUCCIÓN: 3
3. ROLES Y RESPONSABILIDADES 3
3.1 Coordinador de desarrollo 3
3.2 Líder técnico: 3
3.3 Desarrollador 4
3.4 DeVops 4
4. HERRAMIENTAS 5
4.1 ¿Qué es Sonarqube? 5
4.2 ¿Por qué usar sonarqube? 5
4.3 Métricas Principales de Sonarqube 5
- Complejidad 6
- Duplicados 6
- Evidencias 6
- Mantenibilidad 6
- Umbrales de calidad 6
- Tamaño 6

4.4 Características 6
4.5 ¿Qué información nos puede mostrar SonarQube? 7
5 PROCESO 7
5.1 Proceso interno alfa 7
5.2 Proceso externo proveedores 8
6 CONTROLES 8
7 EXCEPCIONES 8
8 CONCLUSION 8

1. OBJETIVO:

Establecer los lineamientos que se deben realizar para contar con buenas prácticas de código seguro en las aplicaciones de Seguros Alfa.

2. INTRODUCCIÓN:

Teniendo en cuenta que La seguridad del software se ha convertido en una prioridad ineludible, para Seguros Alfa la implementación de buenas prácticas de desarrollo de código seguro no sólo es esencial para proteger la integridad y confidencialidad de la información, propender que nuestros productos de software sean de calidad y que cumplan con los requisitos de confiabilidad, mantenibilidad y seguridad, sino también para garantizar la confianza de nuestras personas usuarias y clientes.

Este documento establece las pautas y principios que guiarán al equipo de desarrollo hacia la creación de software robusto y resistente a amenazas cibernéticas, la adopción de prácticas para fortalecer el código contra posibles vulnerabilidades y fomentar una cultura de seguridad arraigada a la generación de código.

3. ROLES Y RESPONSABILIDADES

3.1 Coordinador de desarrollo

Rol del área de tecnología de Seguros Alfa encargado de velar por el cumplimiento del lineamiento de código seguro por medio de la herramienta sonarCube.

Sus responsabilidades son las siguientes:

- Entrega del lineamiento de código seguro de alfa, al líder técnico, gestor del proyecto o responsable técnico que corresponda, para dar cumplimiento al mismo.
- Sesiones periódicas con el líder técnico, gestor del proyecto o responsable técnico que corresponda, para validación del cumplimiento del lineamiento de código seguro de alfa.
- Revisiones periódicas del repositorio de las aplicaciones para validar el cumplimiento del lineamiento de código seguro de alfa.
- Velar por el cumplimiento del plan de remediación del análisis de código seguro de las aplicaciones de alfa arrojado por la herramienta sonarQube.

3.2 Líder técnico:

Rol del área de tecnología de Seguros Alfa, encargado de hacer entrega de la línea base de análisis de código seguro arrojado por la herramienta sonarQube al desarrollador.

Sus responsabilidades son las siguientes:

- Asegurar que, al momento del inicio y final de un desarrollo, se realice el análisis de código seguro de la aplicación que va a ser afectada, lo cual queda documentado de forma automática en la herramienta.
- Validar que al momento de la entrega del desarrollo no se agregaron errores en el código fuente, con la comparación del análisis arrojado por sonarqube, documentando la evidencia de dicho aseguramiento.
- Revisión de la solución de desarrollo entregada por el proveedor o desarrollador para asegurar la calidad de este.

3.3 Desarrollador

Rol responsable de codificar ajustes de desarrollo o nuevas funcionalidades de las aplicaciones de Seguros Alfa con código de calidad.

Sus responsabilidades son las siguientes:

- Validar la entrega de la línea base (análisis de código seguro al inicio del desarrollo), por parte del líder técnico, antes de iniciar el desarrollo.
- Desarrollar la solución del software, asegurando la calidad de este.
- No agregar errores al código fuente.

3.4 DeVops

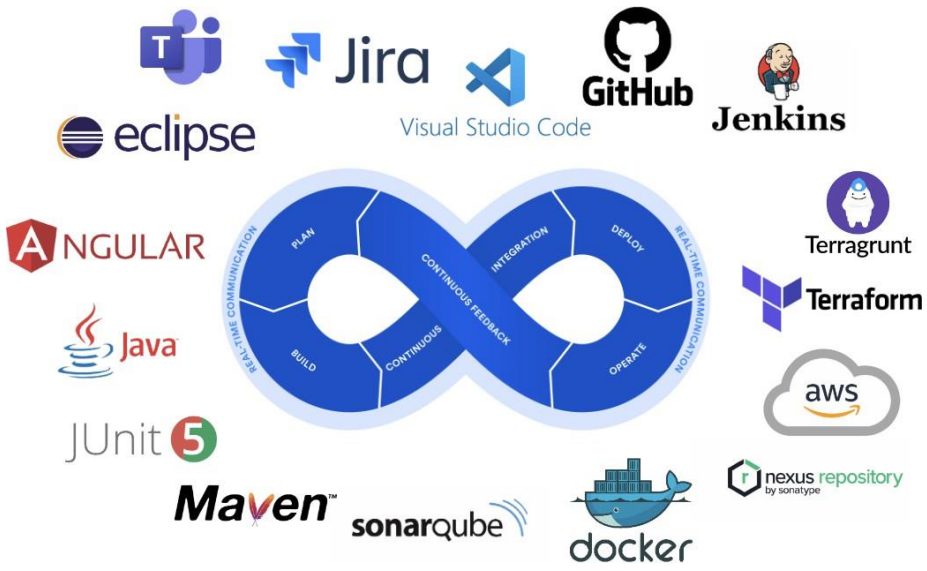
persona encardada de realizar y asegurar la configuración del repositorio de las aplicaciones de seguros alfa, para la ejecución del código seguro por medio de sonarQube.

Sus responsabilidades son las siguientes:

- Configurar en el repositorio de aplicaciones la herramienta de sonarQube.
- Velar por el correcto funcionamiento de la herramienta sonarQube para el análisis del código seguro de las aplicaciones de seguros alfa.

4. HERRAMIENTAS

La herramienta definida por Seguros Alfa para mejorar la seguridad del código es Sonarqube, la cual se encuentra dentro del stack tecnológico de la compañía y como herramienta de código seguro aporta eficiencia, visibilidad y mejora continua en términos de seguridad del código en todo el ciclo de vida del desarrollo de software.



4.1 ¿Qué es Sonarqube?

SonarQube es una herramienta que permite realizar un análisis estático de código. Lo que hace es identificar los puntos susceptibles de mejora, que facilitarán la obtención de métricas necesarias para la optimización del código.

4.2 ¿Por qué usar sonarqube?

Entre las principales bondades que tiene una herramienta de análisis de código estático como SonarQube, se destaca la capacidad de identificar aspectos tales como: código duplicado, código muerto, estándares de codificación, complejidad ciclomática, comentarios, test unitarios y test de integración.

4.3 Métricas Principales de Sonarqube

SonarQube divide las métricas en las siguientes categorías:

- ***Complejidad***

Refleja la Complejidad Ciclomática calculada en base al número de caminos a través del código normalmente observado a nivel de métodos o funciones individuales.

- ***Duplicados***

Nos indica el número de bloques de líneas duplicados. Ayuda a evitar resultados distintos en operaciones iguales.

- ***Evidencias***

Son los fragmentos nuevos de código de un proyecto que detecta que incumplen con alguna de las reglas establecidas.

- ***Mantenibilidad***

Se refiere al recuento total de problemas de Code Smell.

- ***Umbrales de calidad***

Define los requisitos del proyecto antes de ser lanzado a producción, como, por ejemplo, que no debe haber evidencias bloqueantes o la cobertura de código sobre el código nuevo debe ser mayor que el 80%.

- ***Tamaño***

Permiten hacerse una idea del volumen del proyecto en términos generales.

4.4 Características

- Admite los lenguajes de programación mas populares como Java, C/C++, objetive-C, PHP, Flex; Groovy, JavaScript, Python, PL/SQL, COBOL, etc.
- Realiza revisiones automáticas con análisis de código estático detectando problemas que afectan la calidad del código.
- Facilita informes ofreciendo información objetiva de la calidad actual de los proyectos utilizando métricas y gráficos de calidad avanzados. Esto incluye datos sobre códigos duplicados, estándares de codificación, pruebas unitarias, cobertura de código, complejidad del código, errores potenciales, comentarios, diseño y arquitectura.

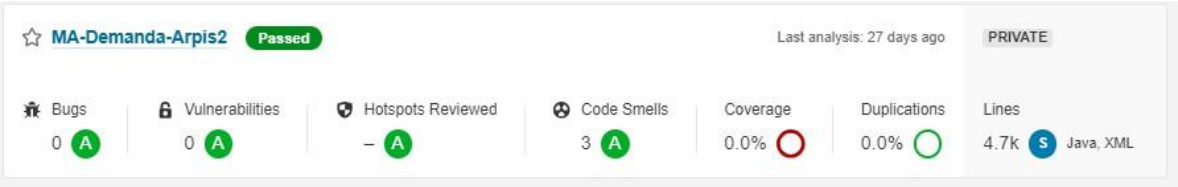
4.5 ¿Qué información nos puede mostrar SonarQube?

- **Quality Gate:** Son una serie de condiciones (reglas) que el proyecto analizado debe cumplir para poder pasar a una siguiente etapa.

- **Bugs y vulnerabilidades:** Hacen referencia tanto a puntos de fallo reales o potenciales en el software, como a puntos débiles de seguridad que pueden ser usados como foco de un ataque.

- **Code smells:** Es un indicativo de que quizás no estamos escribiendo código de la mejor manera, lo que puede ocasionar algún problema en el futuro y un problema de trasfondo, normalmente problemas de mantenibilidad del código. Lo anterior no quiere decir que el código contenga errores o bugs, pero sí puede aumentar el riesgo a errores o fallos.

- **Coverage:** La cobertura de código es una medida que permite conocer el porcentaje de código que ha sido probado o validado por tests. Usualmente se desea obtener una mayor cobertura para tener menos probabilidad de introducir errores en el código.



5 PROCESO

5.1 Proceso interno alfa

- Se debe hacer entrega por parte del Líder Técnico al Desarrollador, antes del inicio de un desarrollo la rama correspondiente para la realización del ajuste y el reporte del análisis de código seguro realizado con sonarQube sobre dicha rama, para generar una línea base de comparación.
- El desarrollador codifica la solución del ajuste solicitado y realiza el merge de la solución a la rama correspondiente.
- Una vez realizado el push a la rama de desarrollo, validar el reporte del análisis de sonarQube, para asegurar que no se agregaron errores en el código fuente con la solución entregada.
- Si el desarrollador evidencia que se agregaron errores en el código fuente, se debe proceder hacer la solución de dichos hallazgos en la rama correspondiente

y proceder a realizar el push, y luego la comparación de los dos reportes de sonarQube nuevamente.

- Una vez solventados todos los errores y al evidenciar que no se agregaron errores en el código fuente, se debe notificar al líder técnico, para proceder a realizar el Pull Request de la rama entregada para el desarrollo a la rama de QA, y se deben adjuntar el resultado de dicha comparación.
- Revisión y aprobación del Pull Request por parte del líder técnico de lo entregado por parte del desarrollador.

5.2 Proceso externo proveedores

- E proveedor al momento de la entrega de la documentación del ajuste del desarrollo solicitado, ya sea proyecto, requerimiento, solución de incidente, garantía, etc. Debe hacer entrega del reporte generado por sonarQube o cualquier herramienta de análisis de código seguro realizada al inicio del ajuste y al final del ajuste, para realizar la comparación y comprobación de que no se estén agregando errores al código fuente de la aplicación, dicha documentación debe ser revisada por la persona encargada por parte de seguros alfa y dar un aval a la solución entregada.

6 CONTROLES

El Coordinador de Desarrollo realizará revisiones periódicas con el Líder técnico para validar que si se estén cumpliendo los lineamientos definidos en este documento

- Como requisito para implementar el nuevo desarrollo en producción, el líder técnico debe anexar a los entregables del cambio, la evidencia del análisis de código seguro realizado al inicio y al final del desarrollo, para que éste sea validado por parte del Comité de Cambios y del Oficial de Seguridad de la Información, miembro del comité de Cambios.

7 EXCEPCIONES

Para le proceso de reporte de sonarQube se cuenta con la excepción para los siguientes archivos:

- .dsx

8 CONCLUSION

La calidad del software tiene cada vez más relevancia en el proceso de desarrollo. SonarQube se convierte así en una plataforma integral para el análisis de código estático y se constituye como una técnica fundamental para la mejora de la calidad del código, reducir la deuda técnica y las vulnerabilidades. La implementación de esta herramienta completa de automatización es, gracias a su sencillez, una ayuda clave para desarrollar un software de calidad.